Asignatura	Datos del alumno	Fecha
Hacking Ético y Análisis de Malware	Nombres: David Muñoz, César Carvallo, Elisabeth Sáez.	03-05-2026

1. Introducción

El presente informe documenta el desarrollo de una práctica de recopilación de información en un entorno controlado de hacking ético. Para ello, se configuró un laboratorio virtual compuesto por una máquina Kali Linux, utilizada como equipo atacante o auditor, y una máquina Metasploitable3 Ubuntu, utilizada como objetivo vulnerable.

La práctica se centró en las primeras fases de una auditoría técnica de seguridad: descubrimiento de hosts, escaneo de puertos, identificación de versiones de servicios, análisis comparativo de distintos tipos de escaneo mediante Wireshark e investigación de vulnerabilidades asociadas a los servicios detectados. No se realizó explotación activa de vulnerabilidades, limitándose el trabajo a la identificación técnica, documentación de hallazgos y propuesta de vectores de ataque potenciales dentro de un marco académico y autorizado.

2. Objetivo

El objetivo de la práctica es aplicar técnicas básicas de reconocimiento y recopilación de información dentro de un laboratorio de ciberseguridad controlado. Específicamente, se busca identificar la máquina objetivo dentro de la red, determinar sus puertos abiertos y versiones de servicios, comparar el comportamiento de distintos tipos de escaneo TCP mediante Wireshark, investigar vulnerabilidades públicas asociadas a los servicios detectados y definir posibles vectores de ataque sin ejecutar explotación.

3. Entorno del laboratorio

<u>Kali Linux:</u>

- Adaptador 1: NAT
- Adaptador 2: Adaptador solo-anfitrión

<u>Metasploitable3:</u>

- Red interna Host-Only

Asignatura	Datos del alumno	Fecha
Hacking Ético y Análisis de Malware	Nombres: David Muñoz, César Carvallo, Elisabeth Sáez.	03-05-2026

Red de laboratorio:

172.28.128.0/24

El entorno de laboratorio fue implementado mediante Oracle VirtualBox. Se utilizó Kali Linux como máquina atacante y Metasploitable3 Ubuntu como máquina objetivo. Para permitir conectividad a Internet y, al mismo tiempo, mantener una red interna aislada para las pruebas, Kali Linux fue configurada con dos adaptadores de red: un adaptador NAT y un adaptador solo-anfitrión.

El adaptador NAT permitió que Kali Linux mantuviera conectividad externa para consultas y actualización de herramientas. El adaptador solo-anfitrión permitió la comunicación directa con Metasploitable3 dentro de la red de laboratorio. Para evitar conflictos de direccionamiento, se utilizó el segmento `172.28.128.0/24`, quedando Kali Linux con la dirección `172.28.128.100` y Metasploitable3 con la dirección `172.28.128.4`.

Esta configuración permitió disponer de un entorno controlado, aislado de redes externas para las pruebas de reconocimiento, cumpliendo con el principio de ejecución autorizada en hacking ético.

Tabla 1. Máquinas del laboratorio

Asignatura	Datos del alumno	Fecha
Hacking Ético y Análisis de Malware	Nombres: David Muñoz, César Carvallo, Elisabeth Sáez.	03-05-2026

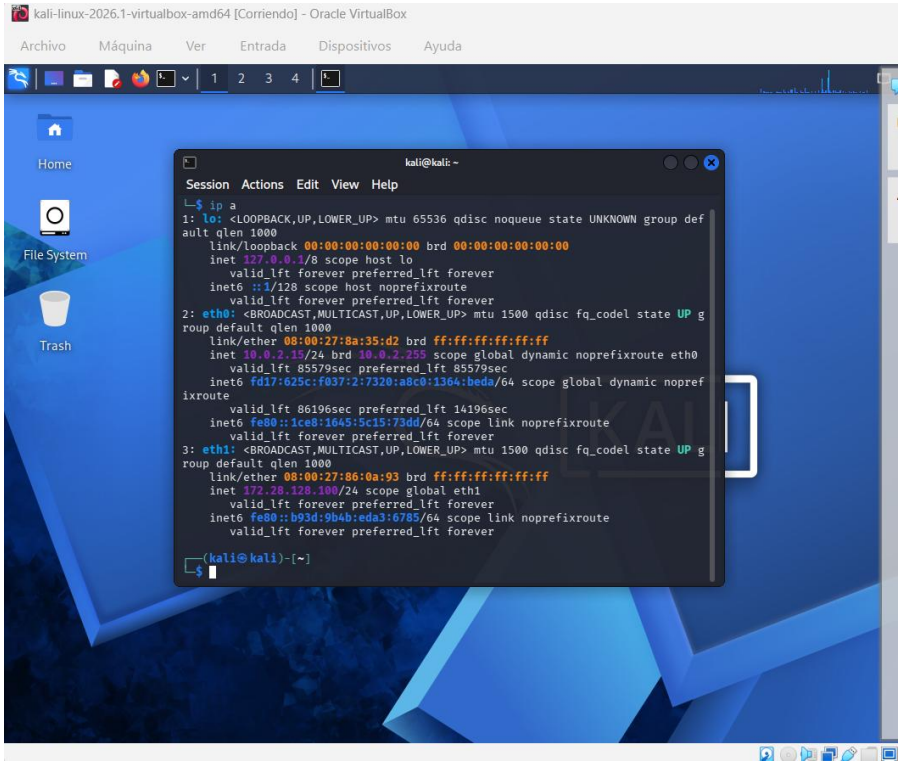

Figura 1. Configuración de interfaces de red en Kali Linux.

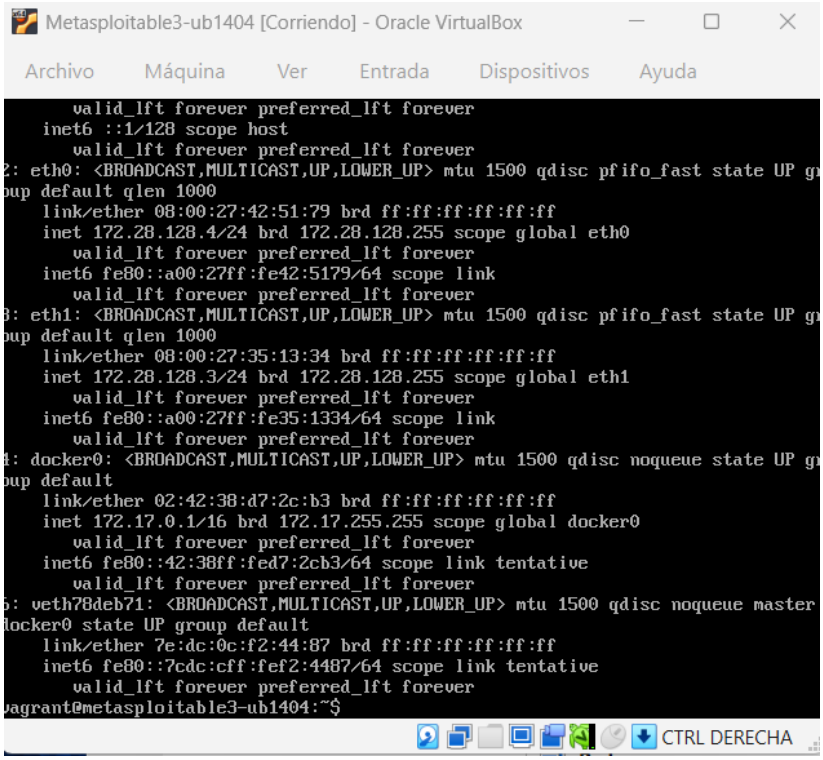

Figura 2. Dirección IP asignada a Metasploitable3 en la red de laboratorio.

4. Verificación de conectividad

Comando utilizado: ping -c 4 172.28.128.4

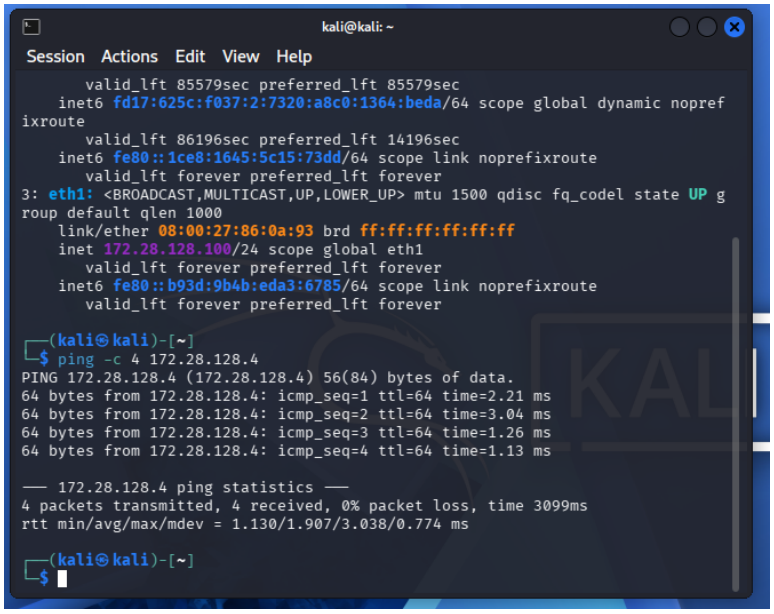

Figura 3. Verificación de conectividad entre Kali Linux y Metasploitable3 mediante ICMP.

Una vez configurado el entorno de red, se verificó la conectividad entre Kali Linux y Metasploitable3 mediante el comando `ping -c 4 172.28.128.4`. El resultado mostró cuatro respuestas ICMP exitosas desde la máquina objetivo y una pérdida de paquetes del 0%, confirmando que ambas máquinas se encontraban correctamente comunicadas dentro del segmento de laboratorio.

5. **Descubrimiento de hosts**

Para identificar los hosts activos dentro del entorno de laboratorio, se utilizó la herramienta Nmap en modo descubrimiento mediante la opción `-sn`. Este tipo de escaneo permite verificar qué equipos se encuentran activos en la red sin realizar un análisis de puertos, por lo que resulta adecuado como primera etapa de reconocimiento.

El comando ejecutado fue: `sudo nmap -sn 172.28.128.1 172.28.128.3 172.28.128.4 172.28.128.100`

El resultado permitió confirmar la presencia de cuatro direcciones activas dentro del segmento de laboratorio. La dirección `172.28.128.1` corresponde al adaptador Host-Only de VirtualBox; la dirección `172.28.128.100` corresponde a la máquina atacante Kali Linux; y las direcciones `172.28.128.3` y `172.28.128.4` se encuentran asociadas a la máquina

Metasploitable3. Para las fases posteriores de escaneo y análisis se seleccionó la dirección `172.28.128.4` como máquina objetivo principal.

Este procedimiento permitió validar la visibilidad entre los componentes del laboratorio y establecer la dirección IP sobre la cual se realizarían los escaneos de puertos, versiones de servicios y análisis de vulnerabilidades.

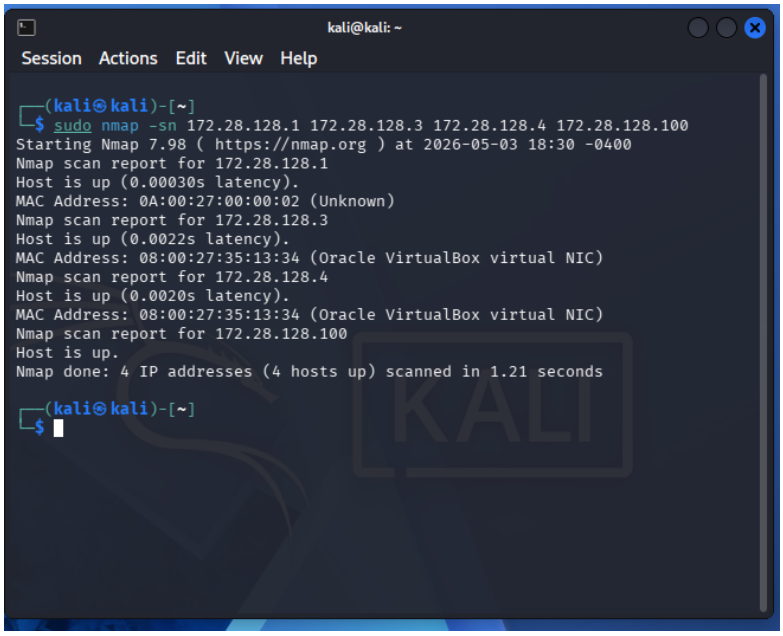

Figura 4. Descubrimiento de hosts activos en el entorno de laboratorio mediante Nmap.

6. Escaneo de puertos y versiones

Una vez identificada la dirección IP de la máquina objetivo, se realizó un escaneo de puertos y detección de versiones mediante Nmap. El comando utilizado fue `sudo nmap -sV 172.28.128.4`, donde la opción `-sV` permite identificar las versiones de los servicios activos en los puertos abiertos.

El escaneo permitió detectar diversos servicios expuestos en la máquina Metasploitable3, entre ellos FTP, SSH, HTTP, SMB, CUPS, MySQL y Jetty. Esta información resulta fundamental dentro de una auditoría técnica, ya que permite asociar servicios y versiones concretas con posibles vulnerabilidades documentadas públicamente.

El resultado también permitió confirmar que el sistema corresponde a una máquina Linux/Unix identificada por Nmap como `METASPLOITABLE3-UB1404`, lo cual es coherente con el entorno vulnerable definido para la práctica.

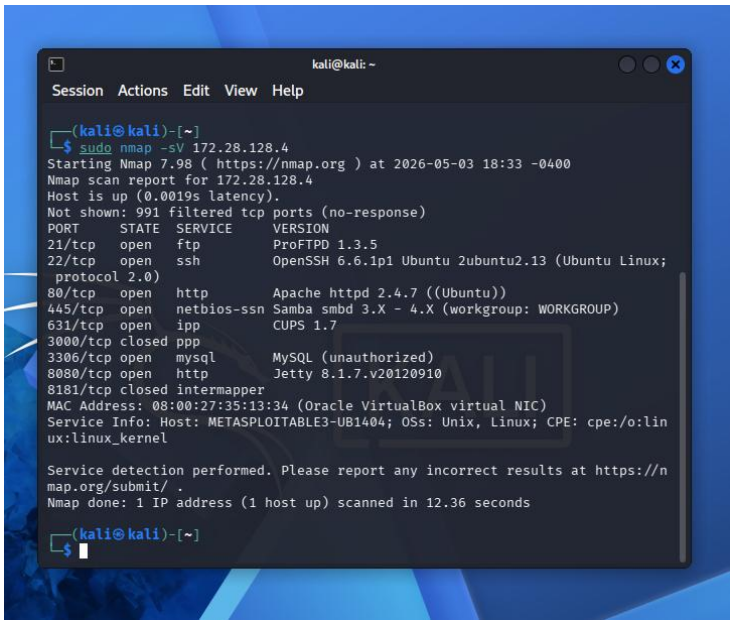

Figura 5. Escaneo de puertos y detección de versiones mediante Nmap sobre Metasploitable3.

Puerto	Estado	Servicio	Versión detectada
21/tcp	open	ftp	ProFTPD 1.3.5
22/tcp	open	ssh	OpenSSH 6.6.1p1 Ubuntu
80/tcp	open	http	Apache httpd 2.4.7
445/tcp	open	netbios-ssn / SMB	Samba smbd 3.X - 4.X
631/tcp	open	ipp	CUPS 1.7
3306/tcp	open	mysql	MySQL no autorizado
8080/tcp	open	http	Jetty 8.1.7
8181/tcp	closed	intermapper	Cerrado

Tabla 1. Puertos abiertos y versiones detectadas en Metasploitable3

6.1 Escaneo TCP SYN

El primer escaneo analizado fue el TCP SYN Scan, ejecutado mediante el comando `sudo nmap -sS -p 21,22,80,445 172.28.128.4`. Este tipo de escaneo envía segmentos TCP con la flag SYN activada hacia los puertos seleccionados, con el objetivo de identificar si estos se encuentran abiertos sin completar completamente la conexión TCP.

En la captura de Wireshark se observa un paquete enviado desde Kali Linux (`172.28.128.100`) hacia Metasploitable3 (`172.28.128.4`) con destino al puerto 445/TCP. En el detalle del protocolo TCP se evidencia la flag `SYN`, representada como `Flags: 0x002 (SYN)`. Posteriormente, la máquina objetivo responde con paquetes `SYN, ACK` en los puertos abiertos, mientras que Kali Linux finaliza el intento de conexión mediante paquetes `RST`.

Este comportamiento corresponde al funcionamiento típico de un escaneo half-open, ya que permite identificar puertos abiertos sin completar el establecimiento formal de la sesión TCP.

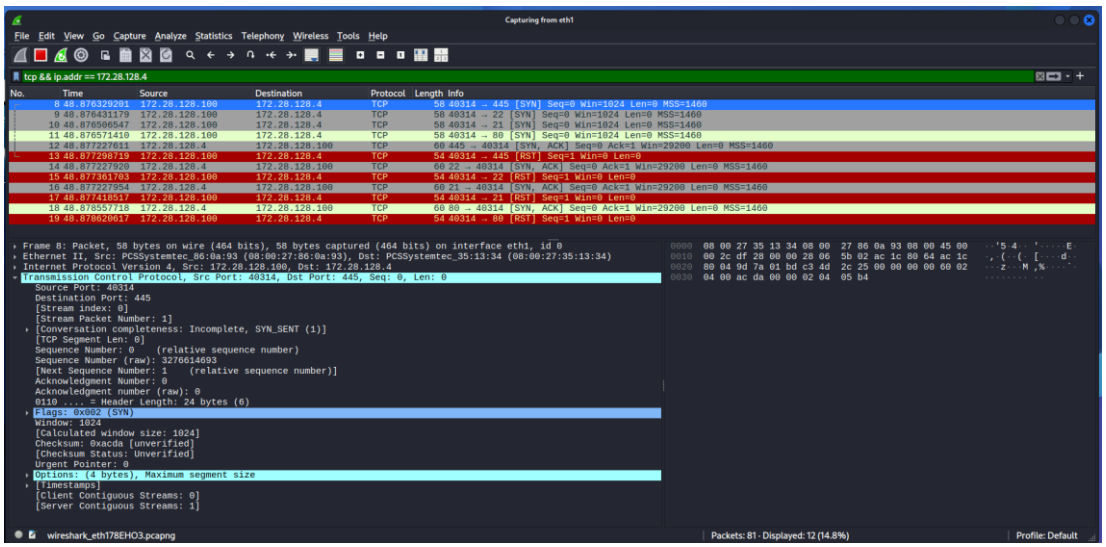

Figura 6. Captura en Wireshark del escaneo TCP SYN, evidenciando la flag SYN en el paquete enviado desde Kali Linux hacia Metasploitable3.

6.2 Escaneo TCP Connect

El segundo escaneo realizado fue un TCP Connect Scan, ejecutado mediante el comando `sudo nmap -sT -p 21,22,80,445 172.28.128.4`. A diferencia del escaneo TCP SYN, este método completa el establecimiento de la conexión TCP mediante el proceso conocido como three-way handshake.

En la captura de Wireshark se observa la secuencia completa de comunicación entre Kali Linux (`172.28.128.100`) y Metasploitable3 (`172.28.128.4`): primero se envía un paquete `SYN`, luego la máquina objetivo responde con `SYN, ACK`, y posteriormente Kali Linux confirma la conexión mediante un paquete `ACK`. En el detalle del paquete seleccionado se evidencia la flag `ACK`, representada como `Flags: 0x010 (ACK)`.

Este comportamiento confirma que el escaneo TCP Connect establece una conexión TCP completa con los puertos analizados, por lo que suele ser más visible para mecanismos de registro, firewalls o sistemas de detección de intrusos.

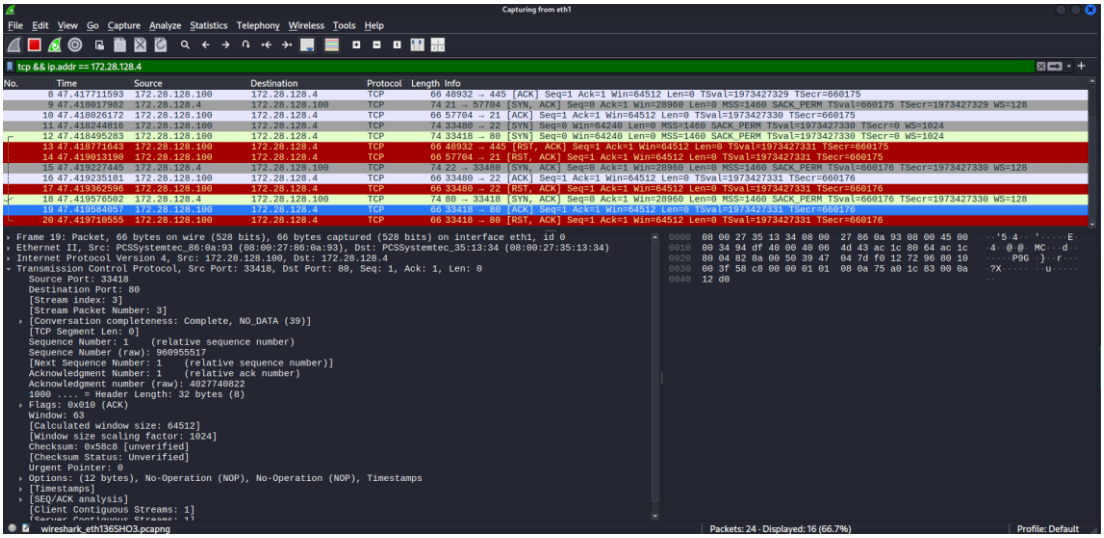

Figura 7. Captura en Wireshark del escaneo TCP Connect, evidenciando la finalización del three-way handshake mediante la flag ACK.

6.3 Escaneo XMAS

El tercer escaneo realizado fue un TCP XMAS Scan, ejecutado mediante el comando `sudo nmap -sX -p 21,22,80,445 172.28.128.4`. Este tipo de escaneo se caracteriza por enviar paquetes TCP con múltiples flags activadas simultáneamente, específicamente `FIN`, `PSH` y `URG`.

En la captura de Wireshark se observa que Kali Linux (`172.28.128.100`) envió paquetes hacia Metasploitable3 (`172.28.128.4`) con las flags `FIN, PSH, URG` activadas. En el detalle del protocolo TCP se evidencia el valor `Flags: 0x029 (FIN, PSH, URG)`, lo que confirma el comportamiento característico de este tipo de escaneo.

Este escaneo resulta útil para observar cómo responde un sistema ante paquetes TCP no convencionales. A diferencia de los escaneos SYN o TCP Connect, el XMAS Scan no inicia una conexión TCP estándar, sino que utiliza una combinación inusual de flags para inferir el estado de los puertos.

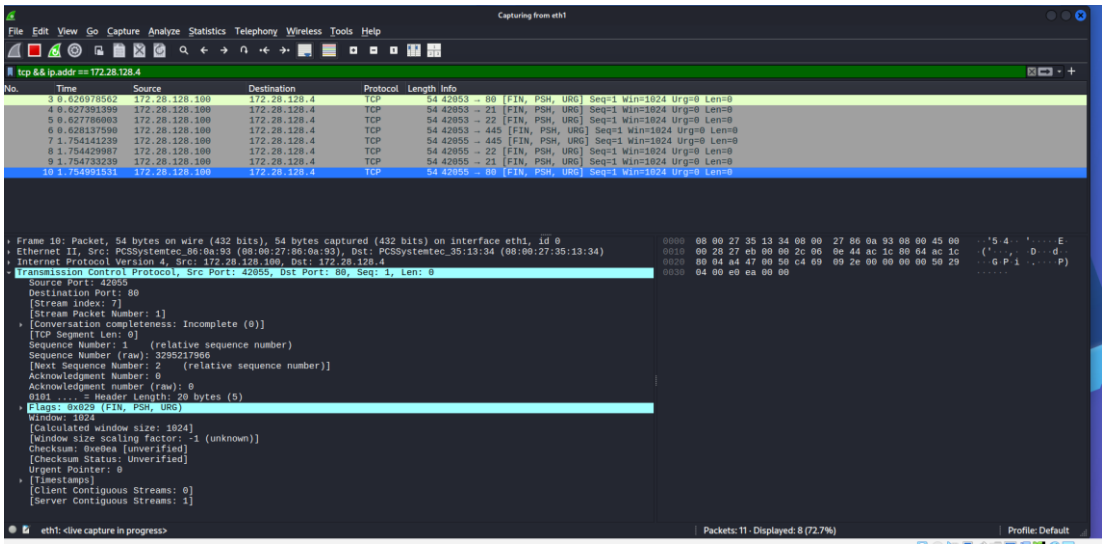

Figura 8. Captura en Wireshark del escaneo TCP XMAS, evidenciando las flags FIN, PSH y URG.

Tipo de escaneo	Comando utilizado	Flags observadas
TCP SYN	sudo nmap -sS -p 21,22,80,445 172.28.128.4	SYN, SYN, ACK, RST
TCP Connect	sudo nmap -sT -p 21,22,80,445 172.28.128.4	SYN, SYN, ACK, ACK
TCP XMAS	sudo nmap -sX -p 21,22,80,445 172.28.128.4	FIN, PSH, URG

Tabla 2. Comparación de escaneos TCP analizados con Wireshark

7. Identificación de vulnerabilidades CVE

A partir de la información obtenida mediante el escaneo de versiones con Nmap, se investigaron vulnerabilidades públicas asociadas a los servicios expuestos por la máquina objetivo. Para ello, se consideraron los servicios y versiones detectadas en los puertos abiertos, priorizando aquellos que cuentan con vulnerabilidades documentadas mediante identificadores CVE.

El análisis se centró en dos servicios relevantes: ProFTPD 1.3.5, expuesto en el puerto 21/TCP, y Samba smbd, expuesto en el puerto 445/TCP. Ambos servicios presentan antecedentes de vulnerabilidades públicas que podrían representar riesgos significativos en un entorno real si no se aplican medidas de mitigación.

7.1 CVE-2015-3306 — ProFTPD 1.3.5

- Identificador: CVE-2015-3306
- Servicio asociado: FTP
- Puerto detectado: 21/TCP
- Versión detectada: ProFTPD 1.3.5

Descripción:

La vulnerabilidad CVE-2015-3306 afecta al módulo mod_copy de ProFTPD 1.3.5. De acuerdo con NVD, este módulo permite que atacantes remotos puedan leer y escribir archivos arbitrarios utilizando los comandos SITE CPFR y SITE CPTO. Esta condición puede comprometer la confidencialidad e integridad del sistema, especialmente si el servicio FTP se encuentra expuesto y mal configurado. :contentReference[oaicite:0]{index=0}

Impacto:

El impacto principal de esta vulnerabilidad radica en la posibilidad de manipular archivos del sistema mediante el servicio FTP. En un escenario vulnerable, un atacante podría copiar archivos internos, escribir contenido no autorizado o preparar condiciones para comprometer otros servicios del servidor. Si el servicio FTP tiene permisos excesivos o acceso a rutas sensibles, el riesgo aumenta considerablemente.

Relación con el laboratorio:

Durante el escaneo de versiones realizado con Nmap, se identificó el servicio ProFTPD 1.3.5 en el puerto 21/TCP de la máquina Metasploitable3. Dado que la CVE-2015-3306 afecta específicamente a ProFTPD 1.3.5, existe una correspondencia directa entre la versión detectada y la vulnerabilidad documentada.

Medidas de mitigación:

Como medidas de mitigación se recomienda actualizar ProFTPD a una versión corregida, deshabilitar el módulo mod_copy si no es estrictamente necesario, restringir el acceso al servicio FTP, aplicar reglas de firewall y revisar los permisos de lectura y escritura asociados al servicio.

7.2 CVE-2017-7494 — Samba Remote Code Execution

- Identificador: CVE-2017-7494
- Servicio asociado: SMB / Samba
- Puerto detectado: 445/TCP
- Versión detectada: Samba smbd 3.X - 4.X

Descripción:

La vulnerabilidad CVE-2017-7494 afecta a Samba desde la versión 3.5.0 y anteriores a las versiones corregidas 4.6.4, 4.5.10 y 4.4.14. Según NVD y el aviso oficial de Samba, esta vulnerabilidad permite que un cliente malicioso cargue una biblioteca compartida en un recurso compartido con permisos de escritura y posteriormente provoque que el servidor la cargue y ejecute. :contentReference[oaicite:1]{index=1}

Impacto:

El impacto de esta vulnerabilidad es alto, ya que puede derivar en ejecución remota de código en el servidor Samba. Para que el ataque sea viable, normalmente se requiere que el atacante tenga acceso a un recurso compartido con permisos de escritura. En un entorno real, esta condición podría permitir la toma de control parcial o total del servicio comprometido, ejecución de código arbitrario y posterior movimiento lateral dentro de la red.

Relación con el laboratorio:

El escaneo de Nmap identificó el servicio Samba smbd 3.X - 4.X en el puerto 445/TCP de la máquina Metasploitable3. La versión detectada se encuentra dentro del rango general afectado por CVE-2017-7494, por lo que esta vulnerabilidad resulta pertinente para el análisis del servicio SMB expuesto.

Medidas de mitigación:

Se recomienda actualizar Samba a una versión corregida, restringir los permisos de escritura en recursos compartidos, limitar el acceso al puerto 445/TCP mediante firewall, deshabilitar recursos compartidos innecesarios y monitorear eventos asociados a cargas de archivos sospechosos en directorios compartidos.

CVE	Servicio	Puerto	Versión detectada	Impacto principal	Condición relevante
CVE-2015-3306	FTP / ProFTPD	21/tcp	ProFTPD 1.3.5	Lectura y escritura arbitraria de archivos	Uso del módulo mod_copy
CVE-2017-7494	SMB / Samba	445/tcp	Samba smbd 3.X - 4.X	Ejecución remota de código	Recurso compartido con permisos de escritura

Tabla 3. Identificación de vulnerabilidades CVE

8. Vector de ataque

Con base en las vulnerabilidades identificadas, se definen vectores de ataque teóricos, sin ejecutar explotación sobre la máquina objetivo. En el caso de ProFTPD 1.3.5, el vector de ataque se relaciona con el abuso del módulo mod_copy mediante comandos FTP específicos que podrían permitir lectura o escritura arbitraria de archivos. En el caso de Samba, el vector se asocia a la carga de una biblioteca compartida maliciosa en un recurso SMB con permisos de escritura, para posteriormente inducir su ejecución por parte del servicio.

En ambos casos, el análisis se limita a la identificación del posible camino de ataque, sin ejecutar payloads, módulos de explotación ni acciones de compromiso sobre la máquina objetivo. Esta decisión responde al alcance académico de la actividad, centrado en reconocimiento, enumeración, análisis de vulnerabilidades y documentación técnica.

Servicio	CVE	Vector de ataque teórico
ProFTPD 1.3.5	CVE-2015-3306	Uso indebido de comandos FTP SITE CPFR y SITE CPTO mediante el módulo mod_copy
Samba smbd	CVE-2017-7494	Carga de biblioteca compartida en recurso SMB escribible para inducir ejecución remota

Tabla 4. Relación entre servicios expuestos, vulnerabilidades CVE asociadas y condiciones técnicas relevantes para su posible explotación.

9. Conclusiones

Asignatura	Datos del alumno	Fecha
Hacking Ético y Análisis de Malware	Nombres: David Muñoz, César Carvallo, Elisabeth Sáez.	03-05-2026

La práctica permitió desarrollar un proceso básico de reconocimiento y recopilación de información dentro de un entorno controlado de hacking ético. En primer lugar, se configuró un laboratorio virtual compuesto por Kali Linux como máquina atacante y Metasploitable3 como máquina objetivo, asegurando la visibilidad entre ambas mediante una red solo-anfitrión.

Posteriormente, se realizó el descubrimiento de hosts activos, identificando la dirección IP de la máquina objetivo. A continuación, se ejecutó un escaneo de puertos y versiones mediante Nmap, lo que permitió detectar servicios expuestos como FTP, SSH, HTTP, SMB, CUPS, MySQL y Jetty. Esta información fue fundamental para vincular los servicios detectados con vulnerabilidades públicas documentadas mediante identificadores CVE.

Asimismo, se analizaron tres tipos de escaneo TCP mediante Wireshark: TCP SYN, TCP Connect y TCP XMAS. Las capturas permitieron evidenciar las diferencias entre los paquetes generados por cada técnica, especialmente en cuanto a las flags TCP utilizadas. Esto permitió comprender de manera práctica cómo varía el comportamiento de los escaneos según el método aplicado.

Finalmente, se investigaron dos vulnerabilidades relevantes asociadas a los servicios detectados: CVE-2015-3306 en ProFTPD 1.3.5 y CVE-2017-7494 en Samba. Para cada una se describió su impacto, relación con el laboratorio, medidas de mitigación y vector de ataque teórico, sin realizar explotación sobre la máquina objetivo.

En conclusión, la actividad permitió aplicar de forma práctica las primeras fases de una auditoría técnica de seguridad, fortaleciendo competencias en reconocimiento, enumeración, análisis de tráfico y documentación de vulnerabilidades. El desarrollo se mantuvo dentro de un entorno académico, controlado y autorizado, respetando los principios del hacking ético.